COMPTIA SECURITY+ SY0-701 DOMÍNIO 4 · OPERAÇÕES DE SEGURANÇA (28%)

Security+ 4.5 · Email Security

Mestre CyberSec · **Aula 4.5 — Email Security** (7:05) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: SPF (lista de IP autorizado), DKIM (assinatura da mensagem), DMARC (política: o que fazer se falhar — reject/quarantine + notifica o dono). Gateway security antispam/antivirus. Encryption: S/MIME, PGP. Sem DMARC qualquer um impersona o domínio.

💡 Highlights que a prova CompTIA cobra

- SPF: lista os IP autorizado; DKIM: assina o corpo
- DMARC: a política — reject/quarantine quando falha; protege contra spoof

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'email spoofing prevented by which combination of protocols'=SPF+DKIM+DMARC

🚨 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 4.5 — Email Security)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Estrutura de Política do Remetente (SPF)

Registro DNS TXT que lista os IPs e hosts autorizados a enviar e-mail por um domínio, ajudando servidores receptores a verificar o remetente do envelope.

⚠ ***Armadilha CompTIA:*** *Se a questão mencionar lista de IPs autorizados, é SPF. SPF valida o envelope/remetente, não o corpo nem o cabeçalho visível da mensagem.*

• DomainKeys Identified Mail (DKIM)

Usa uma assinatura digital adicionada ao cabeçalho ou corpo do e-mail; o servidor receptor valida com uma chave pública no DNS para confirmar integridade e propriedade do domínio.

⚠ ***Armadilha CompTIA:*** *Se mencionar assinatura criptográfica da mensagem, é DKIM. Não autoriza IPs; verifica integridade e autenticidade do domínio assinante.*

• Autenticação, Relatório e Conformidade Baseados em Domínio (DMARC)

Política DNS que instrui servidores receptores sobre como tratar e-mails que falham no alinhamento SPF/DKIM e solicita relatórios; políticas incluem none, quarantine ou reject.

⚠ ***Armadilha CompTIA:*** *Gatilho de prova: combinação que previne spoofing = SPF + DKIM + DMARC. DMARC fornece a política (reject/quarantine) e notifica o dono do domínio.*

• Falsificação de E-mail (N/A)

Falsificar o endereço do remetente de um e-mail para parecer vir de um domínio ou pessoa confiável. Sem DMARC, atacantes podem personificar um domínio.

⚠ ***Armadilha CompTIA:*** *Spoofing é facilitado pela falta de DMARC; SPF/DKIM sozinhos não definem o que fazer se falharem. DMARC protege contra impersonação do domínio.*

• Gateway de E-mail Seguro (SEG)

Appliance ou serviço em nuvem que filtra e-mails de entrada e saída contra spam, phishing, malware e violações de política antes da entrega.

⚠ ***Armadilha CompTIA:*** *Gateway security antispam/antivírus é SEG; atua antes da caixa de correio. Não confundir com criptografia ponta a ponta.*

• Extensões Seguras para Correio Multiuso na Internet (S/MIME)

Padrão para criptografia de chave pública e assinaturas digitais em e-mail, geralmente usando certificados X.509 para confidencialidade e autenticação.

⚠️ ***Armadilha CompTIA:*** *Se a questão falar de certificados digitais/X.509 em e-mail corporativo, é S/MIME. Fornece confidencialidade, integridade e autenticação.*

• Pretty Good Privacy (PGP)

Padrão ou ferramenta de criptografia que usa teia de confiança para confidencialidade, integridade e autenticação de e-mail; frequentemente implementado como OpenPGP.

⚠️ ***Armadilha CompTIA:*** *PGP é associado a web of trust, não a X.509/PKI corporativa. S/MIME usa certificados centralizados; PGP usa confiança descentralizada.*

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Um analista de segurança percebe que atacantes externos estão enviando e-mails com o endereço De visível ceo@contoso.com. A empresa possui um registro SPF válido para contoso.com com -all. A investigação mostra que as mensagens passam no SPF porque os atacantes usam um domínio de remetente de envelope diferente, enquanto o cabeçalho De visível é contoso.com. Qual controle de autenticação de e-mail deve ser implementado para exigir que o domínio De visível esteja alinhado a um domínio autenticado e permita uma política para rejeitar mensagens não alinhadas?

A) S/MIME

B) DKIM

C) DMARC

D) PGP

QUESTÃO 2 · CENÁRIO DE EXAME

Um servidor de e-mail receptor examina um cabeçalho de mensagem que contém uma assinatura criptográfica e um seletor. Ele obtém a chave pública de um registro TXT no DNS para verificar se o conteúdo da mensagem não foi alterado e se o domínio signatário autorizou a mensagem. Qual tecnologia está sendo usada?

A) SPF

B) DKIM

C) DMARC

D) S/MIME

QUESTÃO 3 · CENÁRIO DE EXAME

Uma organização publica um registro DMARC com p=none e recebe relatórios agregados. Após analisar os relatórios, o CISO quer que os receptores bloqueiem mensagens que falharem tanto no alinhamento SPF quanto no DKIM para o domínio da empresa, em vez de apenas monitorá-las. Qual política DMARC deve ser definida?

A) p=none

B) p=quarantine

C) v=spf1 -all

D) p=reject

QUESTÃO 4 · CENÁRIO DE EXAME

Uma equipe de segurança quer receber relatórios XML regulares de grandes provedores de caixa postal resumindo quantas mensagens usando seu domínio passaram ou falharam em SPF, DKIM e DMARC, junto com endereços IP de origem. Qual tag de registro DNS DMARC a equipe deve configurar?

A) rua

B) ruf

C) adkim

D) p

QUESTÃO 5 · CENÁRIO DE EXAME

Uma empresa usa Microsoft Outlook e uma infraestrutura de chave pública interna. Os funcionários devem assinar digitalmente e criptografar e-mails para que os destinatários possam verificar a identidade do remetente e apenas destinatários pretendidos possam ler o conteúdo. A empresa quer integração nativa com Outlook e confiança baseada em certificados. Qual padrão deve ser implantado?

A) PGP

B) S/MIME

C) DKIM

D) SPF

QUESTÃO 6 · CENÁRIO DE EXAME

Um projeto open-source descentralizado precisa trocar e-mails criptografados e assinados sem depender de uma autoridade certificadora corporativa. Os membros preferem um modelo de teia de confiança e já usam ferramentas independentes de gerenciamento de chaves. Qual padrão de segurança de e-mail melhor atende a esse requisito?

A) S/MIME

B) DKIM

C) PGP

D) SPF

QUESTÃO 7 · CENÁRIO DE EXAME

Uma empresa quer inspecionar e-mails de entrada e saída antes que cheguem ao servidor de correio. A solução deve bloquear spam e malware, detectar URLs de phishing e aplicar políticas de prevenção de perda de dados a anexos. Qual tecnologia deve ser implantada?

A) Secure email gateway

B) Registro SPF

C) Registro DMARC

D) Certificado S/MIME

QUESTÃO 8 · CENÁRIO DE EXAME

Um administrador configurou SPF para example.com como v=spf1 include:_spf.google.com -all. Um novo aplicativo de negócios envia e-mails como alerts@example.com por meio de um relay SMTP de terceiros que não está incluído no registro SPF. Os destinatários estão rejeitando os alertas porque o SPF falha. Qual é a correção mais apropriada?

A) Adicionar uma assinatura DKIM aos alertas

B) Adicionar os IPs autorizados do relay ou um mecanismo include ao registro SPF

C) Alterar o DMARC para p=none

D) Substituir SPF por S/MIME

QUESTÃO 9 · CENÁRIO DE EXAME

Uma organização tem registros SPF e DKIM válidos para seu domínio, mas não publicou um registro DMARC. Um atacante envia mensagens de phishing com o domínio da organização no cabeçalho De visível. Qual afirmação descreve melhor a principal lacuna de segurança?

A) O SPF rejeitará automaticamente todas as mensagens com De visível falsificado

B) O DKIM criptografará a mensagem para impedir spoofing

C) Sem DMARC, os receptores não têm uma política de domínio exigindo autenticação alinhada e rejeição/quarentena

D) O S/MIME verificará a mensagem se o destinatário tiver um certificado

QUESTÃO 10 · CENÁRIO DE EXAME

Uma empresa envia e-mails de marketing por uma plataforma de terceiros. As mensagens têm o endereço De visível news@company.com. O SPF passa para o domínio de envelope da plataforma, mas o DMARC falha porque o domínio autenticado por SPF não está alinhado com company.com. A plataforma oferece suporte a assinatura DKIM personalizada. Qual ação é a melhor maneira de fazer o DMARC passar enquanto preserva o De visível?

A) Alterar a política DMARC para p=none

B) Remover o registro SPF

C) Configurar assinatura DKIM com d=company.com

D) Habilitar S/MIME para todos os destinatários

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa C — DMARC

O SPF verifica o domínio do envelope MAIL FROM/Return-Path, então pode passar para o domínio do atacante mesmo que o De visível seja falsificado. O DMARC usa SPF e/ou DKIM com alinhamento de identificador em relação ao cabeçalho De e permite políticas p=reject/quarantine. S/MIME e PGP assinam/criptografam mensagens, mas não aplicam política antisspoofing baseada no domínio.

Questão 2: Alternativa B — DKIM

O DKIM publica uma chave pública em DNS e assina cabeçalhos/corpo, validando integridade e domínio. SPF autoriza IPs para o envelope. DMARC define política/alinhamento. S/MIME usa certificados no nível do usuário, não assinatura por seletor em TXT DNS.

Questão 3: Alternativa D — p=reject

p=none apenas monitora; p=quarantine envia para spam/quarentena; p=reject bloqueia. v=spf1 -all afeta apenas SPF e não define a política DMARC para falhas de alinhamento SPF/DKIM.

Questão 4: Alternativa A — rua

A tag rua especifica URIs para relatórios agregados. ruf é para relatórios forenses/de falha. adkim define o modo de alinhamento DKIM. p define a política.

Questão 5: Alternativa B — S/MIME

S/MIME usa certificados X.509, integra-se ao Outlook e fornece assinatura e criptografia. PGP usa modelo de teia de confiança e ferramentas próprias, com menos integração nativa. DKIM e SPF são autenticação de domínio, não criptografia de mensagem ponta a ponta.

Questão 6: Alternativa C — PGP

PGP usa pares de chaves pública/privada e modelo de teia de confiança, independente de CA. S/MIME depende de CAs. DKIM e SPF fazem autenticação de domínio, não criptografia ponta a ponta.

Questão 7: Alternativa A — Secure email gateway

Um SEG filtra e-mail, anti-spam, antivírus, DLP e filtragem de URL. Registros SPF/DMARC fazem autenticação de domínio. Certificado S/MIME é usado para assinatura/criptografia de mensagens.

Questão 8: Alternativa B — Adicionar os IPs autorizados do relay ou um mecanismo include ao registro SPF

O SPF deve listar todos os remetentes autorizados. DKIM pode ajudar no DMARC, mas o SPF ainda falha; p=none apenas monitora; S/MIME não substitui SPF.

Questão 9: Alternativa C — Sem DMARC, os receptores não têm uma política de domínio exigindo autenticação alinhada e rejeição/quarentena

SPF e DKIM sozinhos podem passar para outros domínios ou não ter alinhamento; DMARC exige alinhamento com o De visível e define política de rejeição/quarentena. SPF não rejeita automaticamente todo spoofing visível; DKIM não criptografa; S/MIME não substitui DMARC.

Questão 10: Alternativa C — Configurar assinatura DKIM com d=company.com

Uma assinatura DKIM com d=company.com alinha com o De visível e pode fazer o DMARC passar mesmo que o SPF esteja alinhado ao fornecedor. p=none apenas monitora; remover SPF piora; S/MIME não tem relação com alinhamento DMARC.